

Vulnerability Assessment Report for Live Website

Future Interns

Cyber Security Internship

Task 1: Vulnerability Assessment Report for a Live Website

Prepared by:
Aaditya Mistry

Date : May 2026

Content

1. Disclosure & Legal Notice-----	4
2. Executive Summary-----	5
3. Objective -----	6
4. Scope -----	7
5. Methodology-----	8
6. Tools-----	9
7. Findings -----	10
7.1 Nmap Assessment Findings-----	10
7.2 OWASP ZAP Assessment Findings -----	12
7.3 Browser Developer Tools Findings -----	14
8. Risk Matrix-----	16
9. Recommendations-----	17
10. Conclusion-----	18
11. References-----	18

Disclosure & Legal Notice

This Vulnerability Assessment Report has been prepared solely for educational and academic purposes as part of the Future Interns Cyber Security Internship Program.

The information contained in this report is intended only for demonstrating cybersecurity assessment techniques, security analysis, and professional reporting practices. All assessments were conducted on authorized, publicly available, or intentionally vulnerable targets in accordance with ethical security testing principles.

The findings, observations, and recommendations presented in this report should not be interpreted as authorization to exploit, misuse, or gain unauthorized access to any system, application, or network. No active exploitation, privilege escalation, denial-of-service testing, or unauthorized activities were performed during this assessment.

Any information contained in this report should be treated as confidential and used solely for educational, research, and security awareness purposes. The author assumes no responsibility for any misuse of the information contained within this document.

This report may not be reproduced, distributed, or used for commercial purposes without appropriate permission from the author.

Executive Summary.

A Vulnerability Assessment was conducted to evaluate the security posture of selected network and web application targets using passive security testing techniques. The assessment was performed using Nmap, OWASP ZAP, and Browser Developer Tools to identify potential security weaknesses, exposed services, and insecure configurations.

Network reconnaissance identified publicly accessible services, software version disclosures, and potential security risks associated with exposed services. Passive web application analysis revealed findings related to missing security headers, session management concerns, information disclosure, and cookie security configurations. Browser-based analysis was also performed to review HTTPS implementation, client-side storage, and browser security controls.

The identified findings were classified according to their risk level and accompanied by practical remediation recommendations. Although no critical vulnerabilities were discovered, several improvements were recommended to strengthen the overall security posture of the assessed systems.

This assessment highlights the importance of regular security reviews, secure configuration practices, and proactive vulnerability management in maintaining a secure environment.

Objective

The primary objective of this assessment was to evaluate the security posture of selected web-based systems through passive vulnerability assessment techniques. The assessment aimed to identify publicly visible security weaknesses, insecure configurations, exposed services, and missing security controls that could potentially increase the attack surface of the target systems.

Specific objectives included:

- Identifying open ports and exposed network services.
- Enumerating service versions and operating system information.
- Detecting common security weaknesses using vulnerability scanning techniques.
- Assessing HTTP security headers and web application security configurations.
- Reviewing session management and cookie security mechanisms.
- Analyzing client-side security controls through Browser Developer Tools.
- Classifying identified findings according to their potential impact and severity.
- Providing practical remediation recommendations to improve overall security posture.

The assessment was conducted strictly for educational purposes using authorized and intentionally vulnerable targets while adhering to ethical security testing principles.

Scope

This assessment focused on identifying security weaknesses through passive vulnerability assessment techniques. The evaluation included network service enumeration, web application security review, and client-side security analysis.

Targets Assessed:

Network Assessment

- Network Target: scanme.nmap.org

Web Application Assessment

- Web Application Target: demo.owasp-juice.shop

Areas Reviewed

- Open ports and running services
- Service and version detection
- HTTP security headers
- Information disclosure
- Session management
- Cookie security configuration
- Browser-based security controls

Out of Scope:

The following activities were not performed:

- Vulnerability exploitation
- Brute-force attacks
- Denial-of-Service testing
- Privilege escalation
- Unauthorized access attempts

Methodology

The assessment was conducted using a structured approach consisting of information gathering, vulnerability identification, and security analysis.

1. Network Reconnaissance

Nmap was used to identify open ports, running services, and software versions exposed by the target system.

2. Vulnerability Assessment

Nmap vulnerability scripts were executed to identify potential security weaknesses and insecure configurations.

3. Passive Web Application Analysis

OWASP ZAP was used in passive scanning mode to review HTTP traffic and identify security issues such as missing headers, information disclosure, and session management weaknesses.

4. Browser Security Review

Browser Developer Tools were used to examine cookies, local storage, network requests, and HTTPS security settings.

5. Risk Classification

Identified findings were categorized as High, Medium, Low, or Informational based on their potential security impact, and remediation recommendations were provided for each finding.

Tools

The following tools were utilized during the vulnerability assessment to perform network reconnaissance, passive web application analysis, and client-side security review.

TOOL	PURPOSE
Nmap	Network scanning, port discovery, service enumeration, and vulnerability script scanning
OWASP ZAP	Passive web application security assessment and identification of common security weaknesses
Browser Developer Tools	Analysis of HTTP traffic, cookies, local storage, HTTPS configuration, and client-side security controls
Github	Documentation, project management, and evidence storage
Canva	Creation and design of the final vulnerability assessment report

These tools were selected because they are widely used within the cybersecurity industry and provide effective capabilities for identifying security weaknesses through passive and non-intrusive assessment techniques.

Findings

1 - Nmap Assessment Findings

Purpose : Network reconnaissance and service enumeration.

Finding 1 : Publicly Accessible SSH Service

Risk Level : Medium

Description : Nmap identified an SSH service running on port 22 that is publicly accessible from the internet.

Evidence : OpenSSH 6.6.1p1 Ubuntu

Impact : Public SSH services may be targeted by unauthorized users attempting password attacks or service enumeration.

Finding 2 : Server Version Disclosure

Risk Level : Medium

Description : The web server disclosed software version information during service enumeration.

Evidence:Apache HTTP Server 2.4.7

Impact : Attackers may use version information to identify publicly known vulnerabilities.

Screenshot :

```
(kali kali)~$ nmap -sV scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-24 01:05 IST
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.038s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.64 seconds
```

Finding 3 : Potential Slowloris DOS Exposure

Risk Level : High

Description : Vulnerability script scanning identified indicators of possible susceptibility to Slowloris denial-of-service attacks.

Evidence : CVE-2007-6750

Impact : An attacker may consume server resources through multiple incomplete HTTP requests.

Finding 4 : Potential CSRF Exposure

Risk Level : Medium

Description : Nmap vulnerability scanning identified forms that may lack adequate protection against Cross-Site Request Forgery (CSRF) attacks.

Evidence : Nmap Vulnerability Script Output

Impact : May allow unauthorized actions to be performed on behalf of authenticated users.

Screenshot :

```
(kali)kali)-[~]
$ nmap --script vuln scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-24 01:08 IST
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.047s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
| http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=scanme.nmap.org
| Found the following possible CSRF vulnerabilities:
|
|   Path: http://scanme.nmap.org:80/
|   Form id: nst-head-search
|   Form action: /search/
|
|   Path: http://scanme.nmap.org:80/
|   Form id: nst-foot-search
|   Form action: /search/
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|   State: LIKELY VULNERABLE
|   IDs: CVE:CVE-2007-6750
|   Slowloris tries to keep many connections to the target web server open and hold
|   them open as long as possible. It accomplishes this by opening connections to
|   the target web server and sending a partial request. By doing so, it starves
|   the http server's resources causing Denial Of Service.
|
|   Disclosure date: 2009-09-17
|   References:
|     http://hacker.org/slowloris/
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_ http-enum:
|_ /images/: Potentially interesting directory w/ listing on 'apache/2.4.7 (ubuntu)'
9929/tcp open nping-echo
31337/tcp open Elite
Nmap done: 1 IP address (1 host up) scanned in 337.96 seconds
```

Additional Nmap Scan Evidence :

```
(kali㉿kali)-[~]
$ nmap scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-24 00:37 IST
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.045s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
9929/tcp  open  nping-echo
31337/tcp open  Elite

Nmap done: 1 IP address (1 host up) scanned in 18.34 seconds
```

```
(kali㉿kali)-[~]
$ nmap -sV scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-24 01:05 IST
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.038s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.64 seconds
```

2 - OWASP ZAP Passive Assessment Results

Purpose : Passive web application security assessment.

Finding 1 : Missing Content Security Policy Header

Risk Level : Medium

Description : The application does not implement a Content Security Policy (CSP).

Evidence : CSP Header Not Set

Impact : The absence of CSP may increase exposure to Cross-Site Scripting (XSS) attacks.

Finding 2 : Missing Anti-Clickjacking Protection

Risk Level : Medium

Description : The application lacks anti-clickjacking security headers.

Evidence : Missing Anti-clickjacking Header

Impact : Attackers may embed the application inside malicious websites to trick users into unintended actions.

Finding 3 : Session ID Exposure Through URL Rewrite

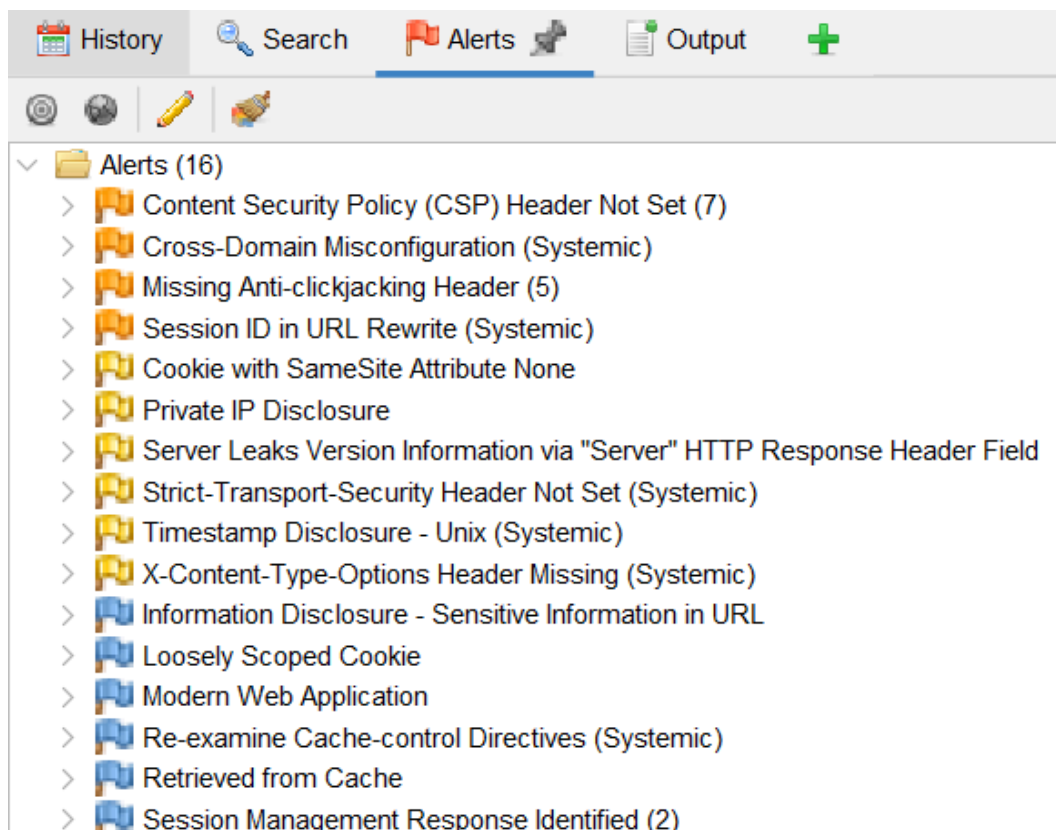
Risk Level : Medium

Description : Session identifiers may be exposed within URL parameters.

Evidence : Session ID in URL Rewrite

Impact : Session information may be disclosed through browser history, logs, or shared URLs.

Screenshot:



3 - Browser Developer Tools Findings

Purpose : Client-side security review and browser-based analysis.

Finding 1 : Secure HTTPS Configuration

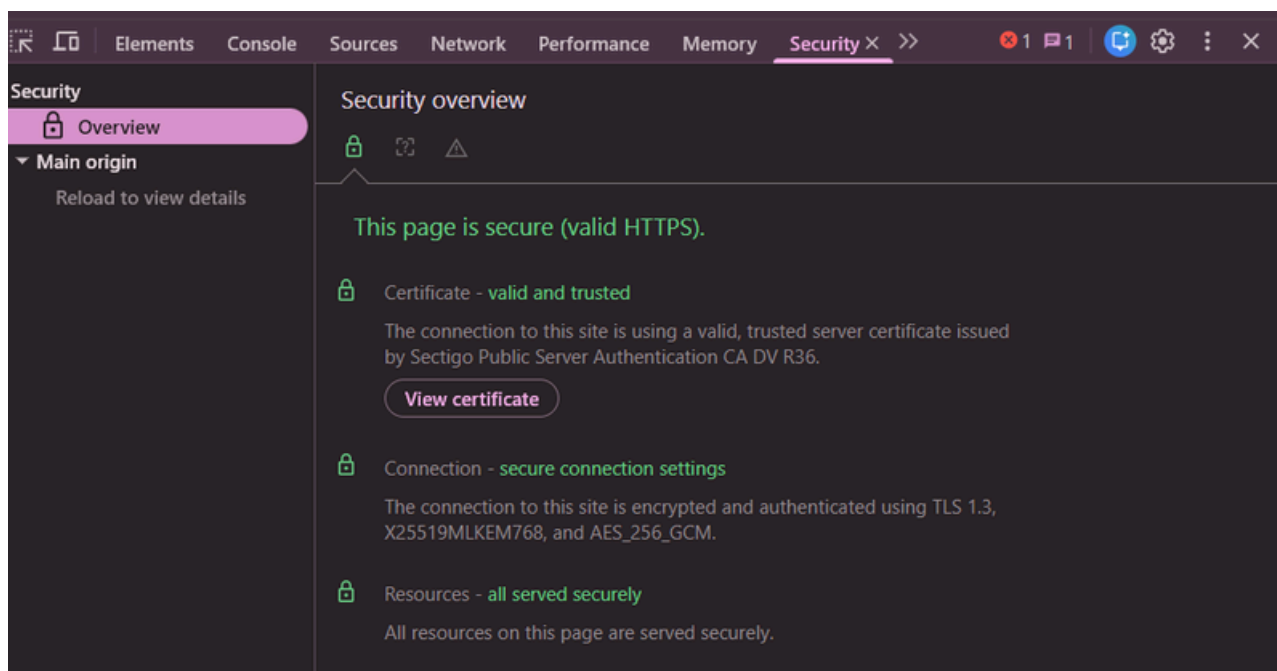
Risk Level : Informational

Description : The application uses HTTPS with a valid TLS certificate.

Evidence : Browser Security Panel

Impact : Encrypted communication helps protect data transmitted between users and the server.

Screenshot :



Finding 2 : Weak Cookie Security Configuration

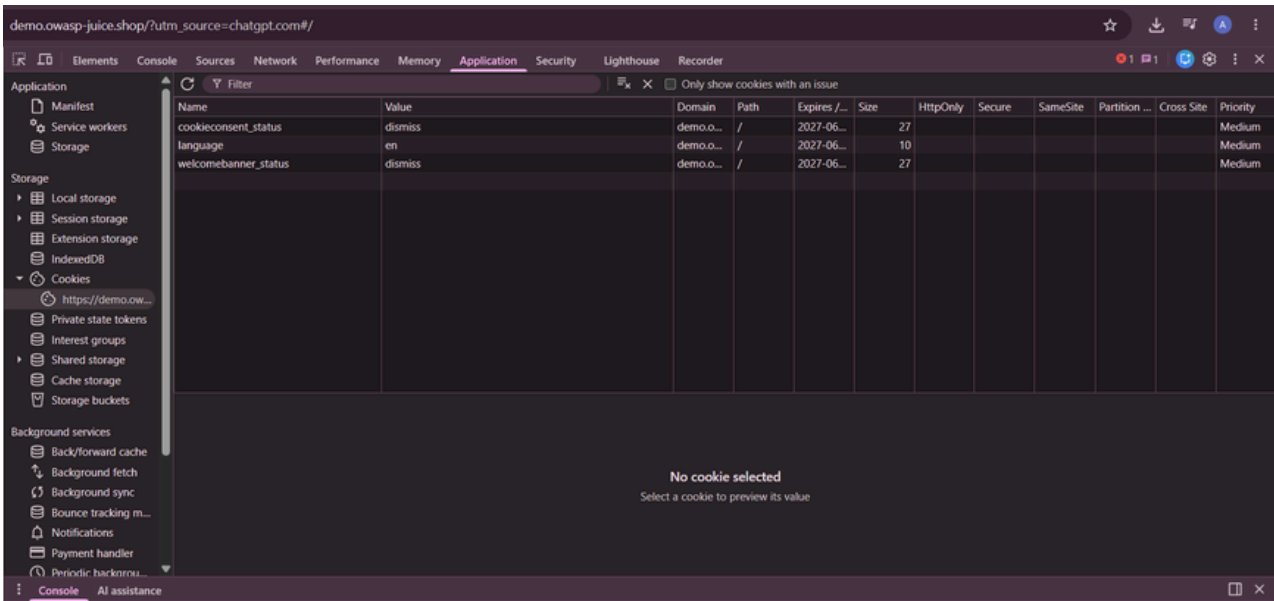
Risk Level : Low

Description : Several cookies were observed without Secure, HttpOnly, and SameSite attributes.

Evidence : Browser Cookie Analysis

Impact : Improper cookie configuration may increase exposure to session-related attacks.

Screenshot :



Finding 3 : Missing Security Headers in HTTP Responses

Risk Level : Medium

Description : Analysis of HTTP response headers indicated the absence of certain recommended security headers.

Evidence : Browser DevTools Network tab was used to inspect HTTP request and response headers.

Impact : Missing security headers may increase exposure to attacks such as XSS, clickjacking, and MIME-type sniffing.

Screenshot :

Name	Status	Type	Initiator	Size	Time
berry_juice.png	304	png	chunk-GJJPXCX3.js:4	0.0 kB	359 ms
artwork2.jpg	304	jpeg	chunk-GJJPXCX3.js:4	0.0 kB	353 ms
braga.jpg	304	jpeg	chunk-GJJPXCX3.js:4	0.0 kB	356 ms
carrot_juice.jpeg	304	jpeg	chunk-GJJPXCX3.js:4	0.0 kB	352 ms
dragonfruit_juice.png	304	png	chunk-GJJPXCX3.js:4	0.0 kB	356 ms
eggfruit_juice.jpg	304	jpeg	chunk-GJJPXCX3.js:4	0.0 kB	352 ms
elderflower_cordial.jpg	304	jpeg	chunk-GJJPXCX3.js:4	0.0 kB	354 ms
fruit_press.jpg	304	jpeg	chunk-GJJPXCX3.js:4	0.0 kB	351 ms
grape_juice.png	304	png	chunk-GJJPXCX3.js:4	0.0 kB	354 ms
green_smoothie.jpg	304	jpeg	chunk-GJJPXCX3.js:4	0.0 kB	350 ms
permafrost.jpg	304	jpeg	chunk-GJJPXCX3.js:4	0.0 kB	352 ms
socket.io/?EIO=4&transport=polling&tt=Pw7ZZ...	200	xhr	polyfills.js:1	0.0 kB	333 ms
socket.io/?EIO=4&transport=polling&tt=Pw7ZZ...	200	xhr	polyfills.js:1	0.1 kB	346 ms
lemon_juice.jpg	304	jpeg	chunk-GJJPXCX3.js:4	0.0 kB	333 ms
favicon.js.ico	304	x-icon	Other	0.0 kB	305 ms
socket.io/?EIO=4&transport=polling&tt=Pw7ZZ-...	(pending)	xhr	polyfills.js:1	0.0 kB	Pending

53 requests | 6.6 kB transferred | 3.5 MB resources | Finish: 3.17 s | DOMContentLoaded: 1.49 s | Load: 2.09 s

Risk Matrix

Risk Level	Description	Number of Findings
High	Vulnerabilities that may significantly impact the availability, confidentiality, or integrity of a system.	1
Medium	Security weaknesses that require remediation to reduce potential risk exposure.	7
Low	Minor security issues with limited impact but recommended for improvement.	3
Informational	Security observations that do not present an immediate risk but provide useful security insights.	1

Risk Distribution Summary :

Tools	High	Medium	Low	Informational
Nmap	1	3	2	0
OWASP ZAP	0	3	0	0
Browser Developer	0	1	1	1

Recommendations

Based on the findings identified during the assessment, the following recommendations are provided to improve the overall security posture of the assessed systems:

- Implement missing HTTP security headers, including Content-Security-Policy (CSP), X-Frame-Options, and X-Content-Type-Options.
- Configure cookies with Secure, HttpOnly, and SameSite attributes to strengthen session security.
- Restrict unnecessary service exposure and review publicly accessible network services.
- Hide server version information to reduce information disclosure during reconnaissance activities.
- Implement anti-CSRF protections on web forms and sensitive application functions.
- Review and secure publicly accessible directories and resources.
- Regularly update server software and apply security patches.
- Conduct periodic vulnerability assessments and security reviews to identify emerging risks.
- Avoid storing sensitive information in client-side storage mechanisms.
- Monitor application logs and security events to detect suspicious activity and potential threats.

Conclusion

A vulnerability assessment was conducted using Nmap, OWASP ZAP, and Browser Developer Tools to evaluate the security posture of the selected targets. The assessment successfully identified several security weaknesses related to service exposure, information disclosure, missing security headers, session management, and client-side security controls.

While no critical vulnerabilities were discovered, multiple medium and low-risk findings were identified that could potentially increase the attack surface of the assessed systems if left unaddressed. Appropriate remediation recommendations have been provided to mitigate these risks and improve overall security.

The assessment highlights the importance of regular security reviews, secure configuration practices, and proactive vulnerability management in maintaining a strong security posture.

References

1. Nmap Documentation – <https://nmap.org/docs.html>
2. OWASP ZAP Documentation – <https://www.zaproxy.org/docs/>
3. OWASP Top 10 – <https://owasp.org/www-project-top-ten/>
4. OWASP Juice Shop – <https://owasp.org/www-project-juice-shop/>
5. Mozilla Web Security Guidelines – <https://developer.mozilla.org/en-US/docs/Web/Security>
6. CWE (Common Weakness Enumeration) – <https://cwe.mitre.org/>
7. CVE Database – <https://www.cve.org/>